

Inventário de APIs e geolocalização

Serviços externos, fluxo de dados, aderência técnica, custos, riscos e LGPD

Campo	Valor
Escopo	Repositório supernova-projeto e integrações configuradas no código
Data da análise	18 de setembro de 2026
Método	Inspeção estática do código, configurações, migrações e testes; confronto com documentação oficial
Limite	Não inclui inspeção das quotas, faturas, restrições de chaves ou contratos nos consoles dos provedores

Conclusão executiva

O produto já cobre o núcleo do fluxo de transporte: consulta de CEP, geocodificação de endereços, confirmação visual do ponto, otimização de múltiplas paradas, exibição da rota e compartilhamento do último ponto do motorista. A separação técnica entre esses papéis é adequada. Os principais riscos não estão na escolha dos serviços, mas na operação: não há cache de CEP ou geocodificação, retries com backoff ou circuit breaker, métricas por provedor, limites internos de consumo, orçamento automatizado, política de retenção das coordenadas ou aviso de privacidade específico para rastreamento.

A maior correção técnica é tratar o rastreamento como dado pessoal de alto impacto operacional: definir base legal e finalidade, reduzir retenção, rejeitar pontos antigos ou implausíveis, registrar acesso e garantir exclusão. Para custos, restringir a chave do Maps JavaScript por domínio e por API, limitar quotas e registrar o número de shipments enviado à Route Optimization API, porque o faturamento ocorre por shipment.

Escopo e critérios

Foram examinados o frontend React, o backend Spring, propriedades de ambiente, migrações do banco e testes. “Usado” significa que existe chamada ou fluxo executável no código. “Configurado” significa que a integração depende de variável ou infraestrutura externa. Recursos citados como alternativa não fazem parte do sistema atual.

Serviços identificados

Serviço	Provedor	Papel atual	Status
ViaCEP	BrasilAPI/ViaCEP	Preenchimento de endereço a partir do CEP	Usado no frontend
Geocoding API do openrouteservice	HeiGIT	Endereço textual para latitude e longitude	Usado no backend quando habilitado
Google Maps JavaScript API	Google Maps Platform	Mapa, marcadores e polyline	Usado no frontend quando há chave
Google Route Optimization API	Google Maps Platform	Sequência e horários de múltiplas paradas	Usado no backend quando habilitado
Geolocation API do navegador	W3C e navegador/SO	Coleta do ponto do motorista	Usado durante viagem ativa
API interna e PostgreSQL	Aplicação Supernova	Transmissão, autorização e último ponto persistido	Usado
SMTP	Provedor configurado pelo operador	Entrega de e-mails transacionais	Integração externa não geográfica
Vercel e banco PostgreSQL gerenciado	Infraestrutura escolhida no deploy	Hospedagem e persistência	Dependência de implantação, não API geográfica

Mapa do fluxo de dados

1. Cadastro: usuário informa CEP → navegador consulta ViaCEP → rua, bairro, cidade e UF preenchem o formulário.
2. Confirmação do ponto: frontend envia endereço ao backend → backend envia texto do endereço ao openrouteservice → recebe coordenadas → frontend carrega Google Maps e permite ajustar o marcador → coordenadas confirmadas voltam ao backend e ficam no cadastro do endereço.
3. Planejamento: backend reúne coordenadas de embarque e desembarque, janelas de tempo e capacidade → envia shipments e um vehicle ao Google Route Optimization → recebe ordem, horários e polyline → persiste o plano da viagem.
4. Execução: navegador do motorista chama watchPosition → envia latitude, longitude, precisão, direção e horário à API interna → backend substitui o último ponto da viagem no PostgreSQL → alunos autorizados consultam o ponto por polling a cada 12 segundos → Google Maps desenha o motorista e a rota.

Matriz dos conceitos

Conceito	O que resolve	Situação no Supernova
Consulta de CEP	Transforma um CEP em componentes postais. Não produz uma coordenada confiável.	ViaCEP no frontend.
Geocodificação	Transforma endereço em coordenadas.	openrouteservice forward geocoding.
Geocodificação reversa	Transforma coordenadas em endereço aproximado.	Ausente.
Exibição de mapas	Renderiza base cartográfica, marcadores e linhas.	Google Maps JavaScript API.
Cálculo de trajetos	Calcula caminho, distância, duração e instruções entre pontos.	Não há chamada independente à Routes API; a polyline vem da otimização.
Matriz de distância e duração	Calcula custos entre várias origens e destinos.	Ausente como API explícita.
Otimização de múltiplas paradas	Escolhe ordem, horários e, em frotas, alocação de tarefas.	Google Route Optimization, com um veículo.
Localização em tempo real	Obtém atualizações do dispositivo.	watchPosition no navegador; melhor esforço em primeiro plano.
Armazenamento e transmissão	Controla quem envia, lê e por quanto tempo o ponto existe.	HTTPS/API interna, JWT/autorização por papel e último ponto no PostgreSQL.

Documentação das APIs

ViaCEP

Item	Análise
Problema resolvido	Consulta de CEP e preenchimento de logradouro, bairro, localidade e UF. Não valida número nem geocodifica.
Onde aparece	frontend/src/lib/postalCode.ts, linhas 8 a 17; consumido por frontend/src/components/PostalCodeInput.tsx.
Dados enviados	CEP com oito dígitos na URL pública GET /ws/{cep}/json/.
Dados recebidos	logradouro, bairro, localidade, uf e sinalizador erro.
Autenticação	Nenhuma.
Custos e limites	Serviço público gratuito. A documentação não publica SLA nem quota numérica; uso massivo pode ser bloqueado. Deve ser tratado como best effort.
Riscos	Chamada direta do navegador expõe o CEP ao provedor; sem timeout explícito, cache, retry ou fallback; dependência sem SLA contratual.
Alternativas	BrasilAPI, API dos Correios/fornecedor comercial, base própria normalizada. Um fallback só deve ser incluído após comparar licença, cobertura e SLA.
Aderência	Uso funcional e simples. Recomenda-se AbortController com timeout, cache por CEP, debounce e fallback operacional.

Geocoding API do openrouteservice

Item	Análise
Problema resolvido	Geocodificação forward: converte endereço brasileiro textual em latitude e longitude.
Onde aparece	backend/.../services/GeocodingService.java, linhas 23 a 101; configuração em application.properties, linhas 51 a 53.
Dados enviados	Rua e número, bairro, cidade, UF e CEP em text; boundary.country=BR, lang=pt e size=1.
Dados recebidos	Primeiro feature, geometry.coordinates em ordem longitude/latitude, confidence e country_a.
Autenticação	Chave no header Authorization. A chave fica apenas no backend.
Custos e limites	Plano público gratuito sujeito às quotas do plano do usuário. A tabela oficial deve ser consultada no momento da contratação; o código não lê headers de quota nem controla orçamento.
Riscos	Sem cache, retry/backoff ou circuit breaker; um único

Item	Análise
	resultado; limiar confidence 0,6 não está calibrado com amostra brasileira; endereço completo é enviado ao terceiro.
Alternativas	Google Geocoding, HERE, Mapbox, TomTom, Nominatim administrado ou geocodificador próprio. Comparar cobertura no Brasil, licença, persistência permitida, SLA e custo.
Aderência	Boas decisões: backend, header Authorization, filtro de país, timeout de conexão de 5 s e leitura de 10 s, validação de limites e mensagem neutra. Melhorias: cache, retries somente para falhas transitórias, métricas, tratamento explícito de 429 e correlação de logs.

Google Maps JavaScript API

Item	Análise
Problema resolvido	Mapa interativo, marcadores, ajuste manual do ponto, polyline planejada e posição do motorista.
Onde aparece	frontend/src/features/location/AddressMap.tsx e LiveTripMap.tsx.
Dados enviados	Chave pública na carga do script; tiles e telemetria de mapa; coordenadas exibidas em marcadores e polyline.
Dados recebidos	Biblioteca JavaScript e conteúdo cartográfico.
Autenticação	VITE_GOOGLE_MAPS_API_KEY incluída no navegador. Isso é esperado para SDK web, mas exige restrição por referer e por API.
Custos e limites	SKU Dynamic Maps: 10.000 carregamentos mensais gratuitos; depois US\$ 7 por 1.000 até 100.000 eventos, na lista global consultada. Quotas publicadas: 30.000 loads/min por projeto e 300 loads/min por IP.
Riscos	Chave sem restrição pode gerar abuso e cobrança; duas funções duplicam o loader; API clássica Marker está funcional, mas convém acompanhar migração para AdvancedMarkerElement; ausência de budget alerts e CSP documentada.
Alternativas	MapLibre GL com tiles contratados, Leaflet com provedor de tiles, HERE, Mapbox ou TomTom. Avaliar licença de tiles, cobertura, custo e atribuição.
Aderência	A forma de carregar a API e exibir dados é válida. Falta confirmar no console: billing, HTTP referrers, restrição exclusiva à Maps JavaScript API, quotas e alertas. Centralizar o loader reduz divergência.

Google Route Optimization API

Item	Análise
Problema resolvido	Otimiza uma sequência de pickups e deliveries com capacidade e janelas de tempo, retornando horários, visitas e polyline.
Onde aparece	backend/.../services/routing/ GoogleRoutePlanningGateway.java, linhas 14 a 225; GoogleCredentialsTokenProvider.java, linhas 10 a 35.
Dados enviados	projectId na URL; período global; um shipment por passageiro com coordenadas de embarque e desembarque, identificador da confirmação, janelas de tempo e demanda; um vehicle com capacidade, início/fim e custos relativos.
Dados recebidos	vehicleStartTime, visits, shipmentIndex, isPickup, startTime, skippedShipments e routePolyline.
Autenticação	OAuth 2.0 com Application Default Credentials e escopo cloud-platform. Token Bearer no backend.
Custos e limites	Com um veículo, usa Single Vehicle Routing: 5.000 shipments mensais gratuitos; depois US\$ 10 por 1.000 shipments até 100.000. OptimizeTours: 60 consultas por minuto. Valores globais consultados em 18/09/2026.
Riscos	Cobrança é por shipment, não por request; retries cegos podem duplicar custo; não há deadline explícito, retry/backoff, quota interna, métrica de shipments/custo ou degradação para rota simples; IDs de confirmação e coordenadas são enviados ao Google.
Alternativas	openrouteservice Optimization/VROOM, GraphHopper Route Optimization, HERE Tour Planning, OptimoRoute/Onfleet ou solver próprio com matriz de rotas. Comparar restrições, tráfego, SLA, privacidade e esforço operacional.
Aderência	O modelo pickup/delivery, capacidade, janelas, um veículo e OAuth no servidor combinam com o caso. Recomendações: usar credencial de workload com mínimo privilégio, deadline, backoff com jitter para 429/5xx, idempotência no nível da aplicação, limite de shipments e telemetria de custo.

Geolocation API do navegador

Item	Análise
Problema resolvido	Obtém atualizações de posição do dispositivo do motorista.
Onde aparece	frontend/src/pages/ActiveTripPage.tsx, watchPosition no ciclo de viagem ativa.
Dados enviados	O navegador/SO determina posição; a aplicação envia latitude, longitude, accuracy, heading e timestamp à API interna.
Dados recebidos	GeolocationPosition e erros de permissão/timeout.
Autenticação	Permissão explícita do usuário; exige contexto seguro HTTPS. Permissions Policy pode restringir a origem.

Item	Análise
Custos e limites	Sem cobrança direta pelo padrão web. Frequência, precisão e disponibilidade dependem do navegador, SO, hardware, economia de bateria e estado da página.
Riscos	watchPosition em PWA/web não garante rastreamento em segundo plano; alta precisão consome bateria; não há detecção de mock location, velocidade impossível, timestamp futuro/antigo ou precisão mínima.
Alternativas	Aplicativo Android/iOS nativo com serviço de localização em primeiro plano e políticas específicas; provedores como Fleet Engine se o produto exigir rastreamento gerenciado.
Aderência	A solicitação ocorre apenas durante viagem ativa e clearWatch é chamado ao desmontar. O filtro de envio (8 m/10 s ou 30 s) reduz tráfego. Falta tela prévia de finalidade, teste de Permissions API, política explícita e fallback quando a aba é suspensa.

Transmissão e persistência da localização

A API interna recebe PUT /api/drivers/me/trips/{id}/location. O backend confirma que o motorista está aprovado, que a viagem pertence a ele e que o status é IN_PROGRESS. Alunos só leem viagens das quais participam. A tabela trip_locations usa trip_id como chave primária; cada atualização substitui o ponto anterior. Portanto, o código não mantém histórico de trilha, mas o último ponto permanece no banco mesmo após o encerramento e apenas deixa de ser retornado enquanto a viagem não está ativa.

Aspecto	Estado atual	Avaliação
Transporte	API web da aplicação; produção deve usar HTTPS.	Correto se TLS e cookies/tokens estiverem configurados.
Autorização	Motorista proprietário escreve; participante lê.	Boa segregação funcional; auditar endpoints e logs.
Frequência	Envio por deslocamento/tempo; leitura a cada 12 s.	É near real time, não streaming.
Persistência	Um registro por viagem.	Minimiza volume, mas falta expurgo após o fim.
Validação	Faixas de latitude/longitude, accuracy não negativa e heading 0–360.	Faltam idade máxima, velocidade, precisão e monotonicidade.
Encerramento	Frontend limpa watch; backend deixa de expor ponto.	Falta exclusão ou anonimização do registro.

Uso recomendado por serviço

Serviço	Parecer	Ação principal
ViaCEP	Parcialmente aderente	Adicionar timeout, cache e fallback; não tratá-lo como validação definitiva.
openrouteservice geocoding	Aderente com lacunas operacionais	Cachear por endereço normalizado; tratar 429/5xx; medir confiança e acurácia.
Google Maps JavaScript	Aderente se a chave estiver restrita	Confirmar HTTP referrers, API restriction, budgets, CSP e política de privacidade.
Route Optimization	Aderente ao modelo de um veículo	Controlar shipments/custo, deadline, retries seletivos e credencial de mínimo privilégio.
Geolocation web	Aderente para uso em primeiro plano	Não prometer rastreamento contínuo em background; explicar permissão e manter fallback.
Persistência interna	Boa minimização por último ponto	Excluir após prazo definido e validar frescor/plausibilidade.

Lacunas e plano de ação

Prioridade	Lacuna	Recomendação verificável
P0	Retenção e base legal	Aprovar inventário LGPD: controlador, operador, finalidade, hipótese legal, destinatários, prazo e canal do titular. Definir expurgo automático de trip_locations após o prazo aprovado.
P0	Segurança das chaves	Restringir a chave Maps por domínio e API; separar produção/homologação; impedir segredo em VITE_* exceto a chave pública restrita; usar ADC/workload identity no backend.
P0	Custo sem guardrails	Criar budget alerts, quotas internas e painel de loads, chamadas, shipments, 429 e custo estimado. Bloquear planejamento acima de limite operacional definido.
P1	Indisponibilidade	Timeout explícito em todos os clientes; retry exponencial com jitter somente para falhas transitórias; circuit breaker; mensagens e fluxo manual quando geocodificação/otimização falharem.
P1	Cache	CEP por CEP normalizado; geocodificação por endereço normalizado com versão/provedor; não cachear conteúdo Google fora das permissões contratuais.
P1	Qualidade da localização	Rejeitar timestamp futuro ou muito antigo, saltos de velocidade impossíveis e pontos com accuracy acima do limite de produto; registrar motivo sem gravar coordenada em logs.
P1	Observabilidade	Métricas por provedor: latência, sucesso, 4xx, 429, 5xx, timeout, cache hit, confiança, shipments e fallback. Trace ID sem endereço/coordinates.
P1	Transparência	Tela antes da permissão explicando finalidade, quem vê, quando termina e retenção; política de privacidade e registro de versão/aceite quando aplicável.
P2	Arquitetura frontend	Unificar o carregador Google Maps, considerar importLibrary e AdvancedMarkerElement, e testar erro de script, chave inválida e quota.
P2	Continuidade móvel	Se rastreamento com tela apagada for requisito, planejar app nativo. Android exige foreground service/notification e regras próprias; iOS prefere When In Use e só admite Always quando necessário.

Política mínima de retenção proposta

Proposta para decisão jurídica e de produto: manter o último ponto somente durante a viagem e por uma janela curta após encerramento para suporte e segurança; depois eliminar trip_locations. Se houver necessidade legítima de prova ou incidente, mover apenas o caso necessário para repositório separado, com acesso restrito, prazo próprio e registro de justificativa. Não manter histórico contínuo por padrão. Endereços e coordenadas cadastrais exigem prazo vinculado à relação do usuário e processo de correção/exclusão.

- Definir base legal antes de produção; consentimento não deve ser escolhido automaticamente se a execução do serviço ou outra hipótese for mais adequada.
- Aplicar necessidade, adequação, transparência, segurança, prevenção e responsabilização.
- Manter registro das operações e avaliar Relatório de Impacto à Proteção de Dados, especialmente pelo acompanhamento de deslocamento e possível presença de estudantes menores de idade.
- Formalizar operadores e transferências internacionais de dados dos provedores; revisar DPA, suboperadores e região de tratamento.

Android e iOS

O código atual é web e depende do navegador. Se virar aplicativo nativo, a implementação deve seguir as permissões da plataforma. No Android, acesso em primeiro plano usa ACCESS_COARSE_LOCATION e, quando necessário, ACCESS_FINE_LOCATION; compartilhamento em background exige justificativa, ACCESS_BACKGROUND_LOCATION e, em muitos cenários, foreground service do tipo location com notificação persistente. No iOS, pedir autorização somente quando o usuário iniciar o recurso; When In Use é a escolha preferida, e Always deve ser reservado a um requisito real de background. As descrições CLLocationWhenInUseUsageDescription e, se aplicável, CLLocationAlwaysAndWhenInUseUsageDescription precisam explicar a finalidade.

O que ainda não existe

Capacidade	Necessidade atual	Quando adicionar
Geocodificação reversa	Não demonstrada	Se o motorista precisar confirmar endereço legível a partir do GPS ou em suporte.
Google Routes API Compute Routes	Não é chamada	Se forem necessárias instruções, ETA/tráfego, alternativas ou rota recalculada independentemente da otimização.
Compute Route Matrix	Não é chamada	Se o produto precisar comparar pares origem/destino, atribuir vários veículos ou pré-calcular custos.
WebSocket/SSE	Não existe; polling de 12 s	Se latência menor ou redução de consultas repetidas justificar complexidade operacional.

Capacidade	Necessidade atual	Quando adicionar
Histórico de trilha	Deliberadamente não existe	Somente com finalidade aprovada, retenção mínima, controles de acesso e impacto LGPD documentado.
Navegação turn by turn	Não existe	Se o produto assumir navegação; avaliar Navigation SDK e custo/licença.

Estimativa de custo e unidades de cobrança

Serviço	Unidade	Faixa gratuita mensal	Preço inicial após faixa
Google Dynamic Maps	Carregamento de mapa	10.000 eventos	US\$ 7 por 1.000 até 100.000
Route Optimization Single Vehicle	Shipment	5.000 shipments	US\$ 10 por 1.000 até 100.000
Google Routes Essentials alternativa	Request ou elemento de matriz	10.000 eventos	US\$ 5 por 1.000 até 100.000
ViaCEP	Consulta	Sem preço; sem SLA/quota numérica publicada	Gratuito, sujeito a bloqueio por uso massivo
openrouteservice	Request conforme plano	Quota do plano público/contratado	Consultar plano vigente da conta

Os preços acima são a lista global oficial consultada na data do relatório, em dólares e antes de impostos, câmbio ou descontos. O custo real precisa ser conferido no billing account. Para a otimização atual, cada passageiro vira um shipment, mesmo contendo pickup e delivery. Assim, uma viagem com 12 passageiros consome 12 unidades faturáveis.

Checklist de implantação

- Google Cloud: APIs corretas habilitadas; billing ativo; quotas; budgets e alertas; service account/ADC; IAM mínimo; chave web com HTTP referrers e API restriction.
- openrouteservice: plano e quota conhecidos; chave rotacionável; 429 monitorado; cache e fallback definidos.
- Aplicação: HTTPS obrigatório; Permissions-Policy geolocation=(self); política CSP; timeouts; retries seletivos; circuit breaker; rate limit por usuário e viagem.
- Dados: prazo de retenção; job de expurgo; logs sem coordenadas/endereço; auditoria de leitura; processo de titular; contratos com operadores.
- Produto: texto pré-permissão; estado claro de GPS; explicação de foreground/background; contingência quando mapa, GPS, geocoding ou otimização estiver indisponível.
- Testes: chave ausente/inválida, 429, 5xx, timeout, CEP inexistente, geocode ambíguo, polyline ausente, ponto antigo, salto impossível e viagem encerrada.

Evidências no código

frontend/src/lib/postalCode.ts:8–17 — chamada direta ao ViaCEP e mapeamento do endereço.

frontend/src/features/location/AddressMap.tsx:5–21 e 23–52 — carga do Maps JavaScript, geocode via backend e ajuste do marcador.

frontend/src/features/location/LiveTripMap.tsx:5–20 e 36–103 — mapa, polyline, paradas e marcador do motorista.

frontend/src/pages/ActiveTripPage.tsx:15–16, 38–58 e 79–83 — polling de 12 s, watchPosition e limiar de envio.

backend/src/main/java/.../services/GeocodingService.java:23–77 — autenticação ORS, timeouts, request, confiança e validação.

backend/src/main/java/.../services/routing/GoogleRoutePlanningGateway.java:41–120 — optimizeTours, shipments, veículo, capacidade e janelas.

backend/src/main/java/.../services/routing/GoogleCredentialsTokenProvider.java:14–33 — ADC, escopo cloud-platform e refresh do token.

backend/src/main/java/.../services/TripTrackingService.java:30–80 — autorização, atualização e leitura do último ponto.

backend/src/main/resources/db/migration/V6__create_trip_live_tracking.sql:3–14 — estrutura trip_locations.

backend/src/main/resources/application.properties:41–53 — endpoints e flags do Google e openrouteservice.

Fontes oficiais

1. [Google Maps JavaScript API setup e restrição de chave](#)
2. [Google Maps JavaScript API uso e faturamento](#)
3. [Google Maps Platform segurança de API](#)
4. [Google Maps Platform preços globais](#)
5. [Google Route Optimization visão geral](#)
6. [Google Route Optimization uso, faturamento e quotas](#)
7. [Google Route Optimization monitoramento](#)
8. [Google Routes API](#)
9. [Google Compute Route Matrix](#)
10. [ViaCEP Webservice](#)
11. [openrouteservice API](#)
12. [openrouteservice restrições](#)
13. [MDN Geolocation API](#)
14. [MDN Permissions Policy geolocation](#)
15. [Android permissões de localização](#)
16. [Android localização em background](#)
17. [Apple autorização de localização](#)
18. [Lei Geral de Proteção de Dados Pessoais](#)
19. [ANPD guia de legítimo interesse](#)

Notas metodológicas

A análise não executou chamadas reais aos provedores, não acessou consoles de faturamento nem inferiu contratos. Quotas de openrouteservice variam por plano e devem ser verificadas na conta.

Preços do Google mudam; por isso o relatório registra data, unidade de cobrança e link oficial. A seção LGPD é uma avaliação técnica de privacidade e não substitui parecer jurídico.